

CCCS 453 – Security Risk Management and Governance

MODULE 5

Assignment #2: Using the NIST Cyber Security Framework

Al Labade, Ayman

The company should formalize and strengthen its communication and coordination with third-party service providers during incidents. To do this, it should create and maintain incident “contact matrix” that lists main and backup contacts, escalation procedures, and expected response times for all critical vendors. This matrix should be integrated into the incident response plan and regularly tested through incident simulations. This recommendation aligns with the NIST Cybersecurity Framework (CSF) Respond – Communications category, specifically **RS.CO-04**, “Coordination with stakeholders occurs consistent with response plans.”

The company should also improve its ability to collect, centralize, and analyze data from detection systems to better investigate incidents and find their root cause. A practical way to do this is by implementing or strengthening a centralized log management or SIEM platform, defining standard investigation workflows, and training analysts on triage and root-cause analysis. This recommendation aligns with the NIST CSF Respond - Analysis category, in particular **RS.AN-01**, “Notifications from detection systems are investigated”, by supporting more structured and effective incident analysis

Finally, the company should establish a formal continuous improvement process to capture these lessons learned after every incident, particularly those involving third parties, and use these lessons to update response plans, playbooks, and training. After each incident, the organization should conduct a post-incident review, document what went well and what did not, and assign follow-up actions with clear owners and deadlines. This aligns with the Respond - Improvements category of the NIST CSF, specifically **RS.IM-01**, “Response plans incorporate lessons learned” and **RS.IM-02**, “Response strategies are updated,” to ensure that the incident response capability improves over time based on real experience.

- **NIST CSF 2.0 main document:**
<https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- **NIST CSF 2.0 Resource & Overview Guide:**
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1299.pdf>
- **NIST CSF Online Reference Tool (functions, categories, subcategories like RS.CO,RS.AN,RS.IM):**
<https://csrc.nist.gov/projects/cybersecurity-framework/filters>

Overall, these three recommendations strengthen the company’s posture in the NIST CSF Respond function by improving third-party coordination, incident analysis, and continuous improvements. By implementing them, the organization can respond to cybersecurity incidents more efficiently and consistently, while building on its existing strengths and mitigation.